The Open Door

Tags: 🌐 Web Exploitation · Medium · VICEROY series **Points:** TBD **Type:** Auto-checked

Description

Scenario Constraint 2: Determine the adversary's access paths.

Before the Phantom actor reached the operator console, they had to break through our perimeter. We have isolated the external Ground-Segment Relay they targeted at `https://sentinel-relay.onrender.com`. Intelligence suggests the attacker utilized automated scanning to find exposed configuration files, and then manipulated an interceptable web request to elevate their privileges.

Setup Instructions

To investigate this web relay, you will use two tools: **Nuclei** (an automated vulnerability scanner) and **Burp Suite** (a web proxy interceptor).

Burp Suite is pre-installed on Kali Linux. You can find it in your main application menu. If you are not using Kali Linux, you can download Burp Suite manually here:
https://portswigger.net/burp/downloads

To install Nuclei and its scanning templates, open your Kali terminal and paste this exact command:

```
      curl -sL
https://raw.githubusercontent.com/holder77/Viceroy_Phantom_Grid_Prep/main/Module_2_
Access/neclei_setup.sh | bash
```

(This will automatically configure the tool and place a 'Nuclei Scanner' shortcut directly on your desktop).

Basic Tool Navigation

If you are new to web exploitation, here is how to operate your tools:

- **Nuclei:** Double-click the shortcut on your desktop, type in the target URL (`https://sentinel-relay.onrender.com`), and press Enter. It will automatically hunt for exposed configuration files.
- **Burp Suite:** Open the application, go to the **Proxy** tab, and click **Open browser**. Use this specific browser window to navigate to the target website. Toggle **Intercept is on** to freeze and edit web traffic before it reaches the server, and click **Forward** to release it.

Your Mission

Your goal is to retrace the Phantom actor's steps to uncover how they bypassed the perimeter. Find both parts of the flag:

1. Use **Nuclei** to scan the target URL for exposed configuration files and extract the first half of the flag.
2. Route your browser traffic through **Burp Suite**, attempt a login, intercept the HTTP request, and manipulate your session privileges to access the dashboard for the second half.

Flag Format:
Combine the two flag fragments into a single string.
Example: `viceroy{part1_part2}`

> **Admin / Organizer Answer Key**
>
> - **Part 1 (Nuclei):** `viceroy{nuc13i_f0und`
> - **Part 2 (Burp Suite):** `_th3_0p3n_d00r}`
> - **Combined Platform Flag:** `viceroy{nuc13i_f0und_th3_0p3n_d00r}`

Hints

- **Hint 1:** The automated Nuclei scan does the heavy lifting for the first flag. When the terminal finishes running, look closely at the text it dumped on your screen. The flag is hiding right below the exposed DB_PASS and SECRET_KEY variables.
- **Hint 2:** The login portal doesn't actually check passwords; it just assigns you a role as an `operator`. Turn **Intercept is on** in Burp Suite *after* you fill out the login form but *before* you click the Authenticate button on the website.
- **Hint 3:** When Burp Suite intercepts the subsequent request to the dashboard, look at the raw HTTP text for a line that says `Cookie: role=operator`. If you manually delete `operator`, type `admin`, and hit **Forward**, the server will blindly trust that you are an administrator!